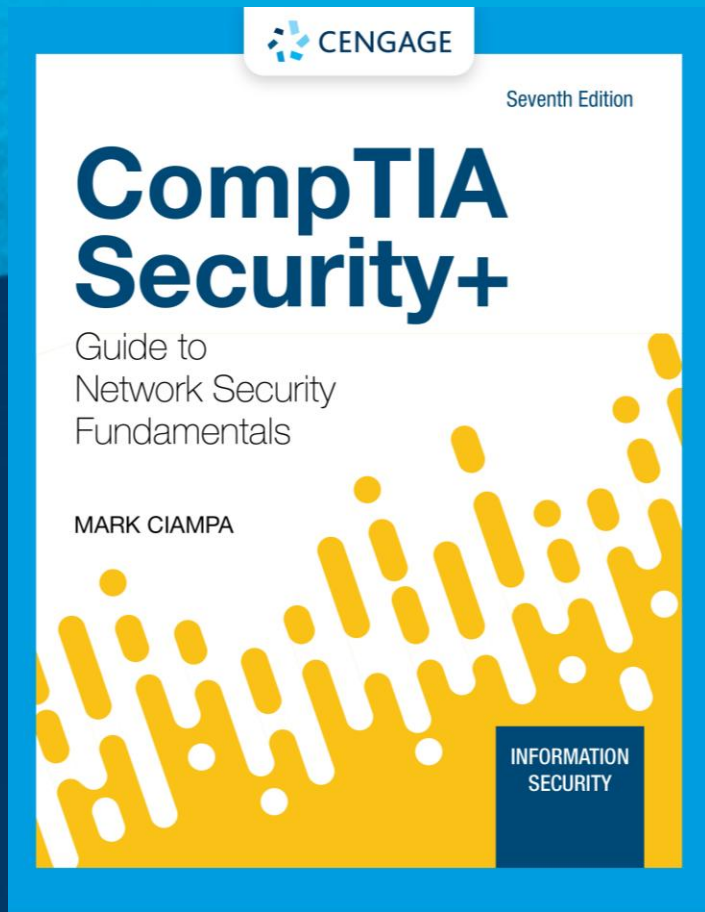




CompTIA Security+ Guide to Network Security Fundamentals, 7th Edition

Module 13: Incident Preparation, Response, and Investigation

Module Objectives

By the end of this module, you should be able to:

1. Explain the steps in preparing for a cybersecurity incident
2. Describe how to respond in an incident
3. List the steps in an incident investigation

Reasons for Cybersecurity Incidents (1 of 13)

- Cybersecurity incidents can be classified into two broad areas: weak account types and poor access control
- Weak Account Types
 - Strong authentication should be required on all user accounts
 - Users accounts should be routinely reviewed for security
 - If necessary, some accounts may need to be deleted or strengthened
 - Any of the following accounts should be prohibited:
 - **Shared account**
 - **Generic account**
 - **Guest account**

Reasons for Cybersecurity Incidents (2 of 13)

- Poor Access Control
 - Access control is granting or denying approval to use specific resources
 - Physical access control consists of fencing, hardware door locks, and mantraps to limit contact with devices
 - Technical access control consists of technology restrictions that limit users on computers from accessing data
 - There are standard access control models that are used to help enforce access control

Reasons for Cybersecurity Incidents (3 of 13)

- Access Control Concepts
- **Identification** is the process of recognizing and distinguishing the user from any other user
 - Example: a delivery driver presenting employee badge
- **Authentication** is performed by checking the credentials
 - Example: examining the delivery driver's badge
- **Authorization** is granting permission to take action
 - Example: allowing the delivery driver to pick up the package
- **Access** is the right given to access specific resources
- **Accounting** is a record that is preserved of who accessed the network, what resources they accessed, and when they disconnected from the network

Reasons for Cybersecurity Incidents (4 of 13)

- Other terminology describes how computer systems impose technical access control:
 - *Object* is a specific resource
 - Example: file or hardware device
 - *Subject* is a user or process functioning on behalf of a user
 - Example: computer user
 - *Operation* is the action taken by the subject over an object
 - Example: deleting a file

Reasons for Cybersecurity Incidents (5 of 13)

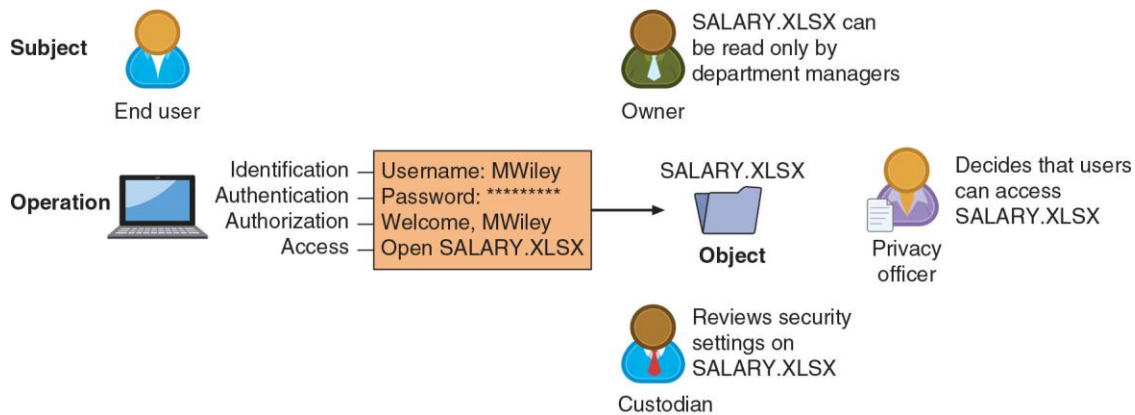


Figure 13-1 Technical access control roles and terminology

Figure 13-1 Technical access control roles and terminology

Reasons for Cybersecurity Incidents (6 of 13)

- Access Control Schemes
 - Access control schemes are standards that provide a predefined framework for hardware or software developers
 - Use the appropriate scheme to configure the necessary level of control is part of **privileged access management**
- There are five major access control schemes
 - *Discretionary Access Control (DAC)*
 - *Mandatory Access Control (MAC)*
 - *Role Based Access Control (RBAC)*
 - *Rule Based Access Control*
 - *Attribute-Based Access Control (ABAC)*

Reasons for Cybersecurity Incidents (7 of 13)

- **Discretionary Access Control (DAC)** scheme is the least restrictive
 - Every object has an owner who has total control over their objects
 - Owners can give permissions to other subjects over their objects
 - This scheme is used on major operating systems
 - DAC has two significant weaknesses:
 - It poses a risk in that it relies on decision by the end user to set the proper level of security
 - A subject's permissions will be "inherited" by any programs that the subject executes

Reasons for Cybersecurity Incidents (8 of 13)

- **Mandatory Access Control (MAC)** is the most restrictive access control model
 - The user has no freedom to set any controls or distribute access to other subjects
 - There are two key elements to MAC:
 - *Labels* - Every entity is an object and is assigned a classification label that represents the relative importance of the object
 - *Levels* - a hierarchy based on the labels is used
 - MAC grants permissions by matching object labels with subject labels
 - The labels indicate level of privilege
 - Microsoft Windows uses a MAC implementation called *Mandatory Integrity Control (MIC)*

Reasons for Cybersecurity Incidents (9 of 13)

- **Role-Based Access Control (RBAC)** is sometimes called *Non-Discretionary Access Control*
 - Access permissions are based on the user's job function
 - RBAC assigns permissions to particular roles in an organization
 - Users are then assigned to those roles
 - Objects are set to be a certain type, to which subjects with that particular role have access

Reasons for Cybersecurity Incidents (10 of 13)

- **Rule-Based Access Control** is also called *Rule-Based Role-Based Access Control (RB-RBAC)*
- Dynamically assigns roles to subjects based on a set of rules defined by a custodian
- Each resource object contains access properties based on the rules
- When a user attempts access, the system checks the object's rules to determine access permission
- Often used for managing user access to one or more systems
 - Business changes may trigger application of the rules specifying access changes

Reasons for Cybersecurity Incidents (11 of 13)

- **Attribute-Based Access Control (ABAC)** uses more flexible policies than Rule-Based AC
 - ABAC can combine attributes
 - Policies can take advantage of attributes such as:
 - Object attributes
 - Subject attributes
 - Environment attributes
 - ABAC rules can be formatted using an *If-Then-Else* structure

Reasons for Cybersecurity Incidents (12 of 13)

- **Access Control Lists (ACLs)**
 - An ACL is a set of permissions attached to an object
- An ACL specifies which subjects may access the object and what operations they can perform
- When a subject requests to perform an operation on an object, the system checks the ACL for an approved entry
- ACLs are usually viewed in relation to operating system files
- ACLs provide **file system permissions** for protecting files managed by the OS
- ACL have also been ported to SQL and relational database systems so that ACLs can provide database security

Reasons for Cybersecurity Incidents (13 of 13)

- The following are limitations of ACLs:
 - Using ACLs is not efficient
 - ACLs can be difficult to manage in an enterprise setting where many users need to have different levels of access to many different resources
 - Adding, deleting, and changing ACLs on individual files can be time consuming and open to errors

Preparing for an Incident (1 of 4)

- Creating an Incident Response Plan
 - An **incident response plan (IRP)** is a set of written instructions for reacting to a security incident
 - An **incident response process** includes six action steps to be taken when an incident occurs:
 - Preparation
 - Identification
 - Containment
 - Eradication
 - Recovery
 - Lessons learned

Preparing for an Incident (2 of 4)

- At a minimum, an IRP should contain the following:
 - Documented incident definitions
 - Incident response teams
 - Reporting requirements/escalation
 - Retention policy
 - Stakeholder management
 - Communication plan

Preparing for an Incident (3 of 4)

Exercise Name	Description	Example
Tabletop	A monthly 30-minute discussion of a scenario conducted in an informal and stress-free environment.	This scenario is presented: An employee casually remarks about how generous it is of a vendor to provide the box of USB drives on the conference room table, embossed with the company logo. After making some inquiries, you find the vendor did not provide USB drives to employees. What do we now do?
Walkthrough	A review by IT personnel of the steps of the plan by paying particular attention to the IT systems and services that may be targeted in an attack.	A technician with knowledge of the current system will walk through the proposed recovery procedures to determine if there are omissions, gaps, errors, or false assumptions.
Simulation	A hands-on simulation exercise using a realistic scenario to thoroughly test each step of the plan.	A simulation of a senior vice president who opens a malicious attachment and introduces malware into the network is presented.

Preparing for an Incident (4 of 4)

- Studying Attack Frameworks
 - Exploitation frameworks serve as models of the thinking and actions of today's threat actors
 - Three common attack frameworks include the following:
 - *MITRE ATT&CK*
 - *The Diamond Model of Intrusion Analysis*
 - *Cyber Kill Chain*

Knowledge Check Activity 1

In which type of access control can access policies be based on the properties of objects, subjects, and the environment and can be constructed using If-Then-Else statements?

- a. Rule-Based Access Control
- b. Role-based Access Control
- c. Attribute-Based Access Control
- d. Discretionary Access Control

Knowledge Check Activity 1: Answer

In which type of access control can access policies be based on the properties of objects, subjects, and the environment and can be constructed using If-Then-Else statements?

Answer: c. Attribute-Based Access Control

With Attribute-Based Access Control (ABAC), rules can be formatted using an If-Then-Else structure and policies can take advantage of attributes of objects, subjects, and the environment.

Incident Response

- Steps that should be taken when responding to an incident include:
 - Taking advantage of SOAR runbooks and playbooks
 - Performing containment
 - Making configuration changes

Use SOAR Runbooks and Playbooks

- A **Security Orchestration, Automation, and Response (SOAR) product** can help security teams manage and respond to security warnings and alarms
 - A SOAR allows a security team to automate incident response
- A **playbook** is a linear-style checklist of required steps and actions needed to successfully respond to specific incident types and threats
- A **runbook** is a series of automated conditional steps that are part of an incident response procedure
 - A playbook focuses more on manual steps to be performed and a runbook is usually actions that are performed automatically
- Most SOAR platforms have pre-configured “out-of-the-box” playbooks that are based on industry best practices and recognized standards

Perform Containment

- Containment is limiting the spread of the attack
 - Containment can be most effective when the network has been properly designed
- A secure network design takes advantage of *network segmentation* based upon the principle of zero trust
- Network segments can be created based on business units, locations, or the level of sensitivity of the network data
- Network segmentation only restricts attackers by limiting access to other parts of the network
 - When an attack occurs, **isolation** is then used to segregate both the attacker and the infected systems from reaching other devices

Make Configuration Changes

- To neutralize an attacker, limit the spread of the attack, and prevent additional successful incidents, it may be necessary to make configuration changes to devices and processes
- Configuration changes may need to be applied to the following:
 - Firewall rules
 - Content/URL filters
 - Digital certificates
 - Data loss prevention settings
 - Mobile device management settings

Knowledge Check Activity 2

What must be incorporated into network design to restrict attackers by limiting access to other parts of the network?

- a. Data loss prevention
- b. Content filters
- c. A runbook
- d. Network segmentation

Knowledge Check Activity 2: Answer

What must be incorporated into network design to restrict attackers' access to parts of the network and then isolate when an attack occurs?

Answer: d. Network segmentation

A secure network design takes advantage of network segmentation. Network segmentation restricts attackers by limiting their access to other parts of the network and allows the attacker to be isolated if an attack occurs.

Incident Investigation

- A cybersecurity incident should be fully investigated
- Reasons to investigate include:
 - To pinpoint how the incident occurred so that future incidents can be prevented
 - For regulatory compliance reporting
- Incident investigations involves:
 - Analyzing data sources
 - Performing a digital forensics investigation

Data Sources (1 of 4)

- Log Files
 - Using data from log files involves identifying log file sources, collecting data, and analyzing data
 - Security logs can reveal the type of attacks that was directed at the network and how it successfully circumvented existing security defenses
 - Network-based device logs provide beneficial security data for an investigation
 - System log files (authentication servers in particular) should be investigated
 - Application log files can give information about attacks focused on different applications
 - Vulnerabilities in voice and video communication are often compromised to allow attackers to pivot to other resources

Data Sources (2 of 4)

- Log Files (continued)
 - Problems associated with log management are due to the following:
 - Multiple devices generating logs
 - Very large volume of data
 - Different log formats
 - Solutions to these problems can be seen in Table 13-7 on the following slide

Data Sources (3 of 4)

Solution	Description
syslog	syslog (system logging protocol) is a standard to send system log or event messages to a server.
nxlog	nxlog is a multi-platform log management tool and supports various platforms, log sources, and formats.
rsyslog	rsyslog (rocket-fast system for log processing) is an open source utility for forwarding log messages in an IP network on UNIX devices.
syslog-ng	syslog-ng is an open source utility for UNIX devices that includes content filtering.
journalctl	journalctl is a Linux utility for querying and displaying log files.

Data Sources (4 of 4)

- Other Data Sources
 - Data can be accumulated from other sources including the following:
 - *IP monitors*
 - *Metadata*
 - *Analyzers*
 - *Vulnerability scans*

Digital Forensics (1 of 10)

- What is Forensics?
 - Forensic science is the application of science to legal questions
 - Forensics can be applied to technology
 - Digital forensics uses technology to search for computer evidence of a cybercrime
 - Digital evidence can be retrieved from computers, mobile devices, cell phones, digital cameras, and virtually any device that has a processor, memory, or storage

Digital Forensics (2 of 10)

- Forensics Procedures
 - When responding to an incident, five basic steps are followed:
 - Secure the crime scene
 - Preserve the evidence
 - Establish a chain of custody
 - Examine the evidence
 - Enable recovery

Digital Forensics (3 of 10)

- Secure the Scene
 - Individuals in the immediate vicinity should perform damage control:
 - Contact the incident response team
 - Secure physical security features
 - Quarantine electronic equipment
 - If necessary, report the incident to the appropriate external authorities
 - After the response team arrives, the first job is to secure the crime scene, which includes:
 - Physical surroundings should be documented
 - Photographs taken before anything is touched
 - Computer cables should be labeled
 - The team takes custody of entire computer along with any peripherals
 - The team interviews witnesses

Digital Forensics (4 of 10)

- Preserve the Evidence
 - **Preservation of the evidence** involves ensuring that important proof is not destroyed
 - Digital evidence is very fragile
 - Evidence should be placed in bags that have tags or identifying labels
 - Bags should be sealed to protect the evidence from being altered
 - A tamper-evident seal is a seal or tape that cannot be removed and reapplied without leaving obvious visual evidence
 - A tamper-resistant seal is designed to deter tampering with the bag
 - If necessary, the judicial system may need to be involved to ensure the integrity of the evidence is maintained and can hold up in a court of law (admissibility)

Digital Forensics (5 of 10)

- Document Chain of Custody
 - Documenting the evidence from the very beginning is called **provenance**
 - Chain of custody documents that the evidence was maintained under strict control at all times and no unauthorized person was given opportunity to corrupt the evidence
 - A chain of custody includes documenting:
 - All serial numbers of systems involved
 - Who handled and had custody of the systems and for what length of time
 - How the computer was shipped
 - Any other steps in the process

Digital Forensics (6 of 10)

Description of Evidence		
Item #	Quantity	Description of Item (Model, Serial #, Condition, Marks, Scratches)

Chain of Custody				
Item #	Date/Time	Released by (Signature & ID#)	Received by (Signature & ID#)	Comments/Location

Final Disposal Authority	
Item(s) #: _____ on this document pertaining to (suspect): _____ Is/are no longer needed as evidence and is/are authorized for disposal by (check appropriate disposal method) ☐ Return to Owner ☐ Auction/Destroy/Divert Name & ID# of Authorizing Official: _____ Signature: _____ Date: _____	

Witness to Destruction of Evidence	
Item(s) #: _____ on this document were destroyed by Evidence Custodian _____ ID#: _____ In my presence on (date) _____ Name & ID# of Witness to destruction: _____ Signature: _____ Date: _____	

Release to Lawful Owner	
Item(s) #: _____ on this document was/were released by Evidence Custodian _____ ID#: _____ to _____ Name _____ Address: _____ City: _____ State: _____ Zip Code: _____ Telephone Number: (____) _____ Under penalty of law, I certify that I am the lawful owner of the above item(s). Signature: _____ Date: _____ Copy of Government-issued photo identification is attached. ☐ Yes ☐ No	

This Evidence Chain-of-Custody form is to be retained as a permanent record.

Figure 13-8 Chain of custody form

Figure 13-8 Chain of custody form

Digital Forensics (7 of 10)

- Examine for Evidence
 - An **order of volatility** must be followed when examining evidence in order to preserve the most fragile data first
 - After a computer forensics expert creates a mirror image of a system, the original system is secured and the mirror image is examined to reveal evidence
 - Mirror image backup programs rely upon hashing algorithms as part of the validation process
 - Two elements frequently overlooked during an investigation include:
 - The **swap file** (or pagefile)
 - **Firmware**
 - Hidden clues also can be exposed by examining
 - RAM slack, drive slack, and metadata (data about data)

Digital Forensics (8 of 10)

- Enable Recovery
 - A final analysis looks at recovering the data from the security event and the lessons that can be learned from it
 - **Strategic intelligence** is the collection, processing, analysis, and dissemination of intelligence for forming policy changes
 - **Strategic counterintelligence** involves gaining information about the attacker's intelligence collection capabilities

Digital Forensics (9 of 10)

- Forensics Tools
 - Software forensics tools include the following:
 - A utility named DD (sometimes called DNU dd) is an imaging utility that requires only minimal resources to run and generates raw image files that can be read by many other programs
 - Memdump is a Linux utility that “dumps” system memory
 - WinHex
 - Autopsy
 - Hardware forensics tools include the following:
 - A digital forensic workstation
 - A mobile device forensics tool

Digital Forensics (10 of 10)

- Cloud Forensics
 - When dealing with a cloud incident, the following should be considered:
 - A right to audit clause in a cloud contract gives the customer the legal right to review the logs
 - When a cloud customer is notified by its cloud provider that an incident occurred, the immediate response will be to ask for details about the scope of the impact
 - ▶ The cloud provider may take weeks or months to provide this
 - The legal **regulatory/jurisdiction** laws that govern the site in which the cloud data resides may present difficulties

Knowledge Check Activity 3

When discussing the chain of custody of evidence in a cybercrime, what does provenance mean?

- a. Preservation of the evidence to ensure it is not destroyed
- b. Ensuring that collected evidence is admissible
- c. Documenting custody of the evidence from the beginning of the investigation
- d. Securing the scene of the crime until the response team arrives

Knowledge Check Activity 3: Answer

When discussing the chain of custody of evidence in a cybercrime, what does provenance mean?

Answer: c. Documenting the evidence from the beginning of the investigation

Provenance is the documentation of the custody of evidence from the beginning of the investigation to show that it was always under strict control and could not be tampered with.

Self-Assessment

To ensure that you have achieved the objectives of this module, write a short summary (two to three sentences) of what you learned based on each module objective. Review the module sections that relate to any objective for which you are having difficulty writing the summary:

1. Explain the steps in preparing for a cybersecurity incident
2. Describe how to respond in an incident
3. List the steps in an incident investigation

Summary (1 of 2)

- Access control is granting or denying approval to use specific resources
- An access control list (ACL) is a set of permissions that is attached to an object
- An incident response plan is a set of written instructions for reacting to a security incident
- It is important to test an incident response plan by conducting exercises to make necessary adjustments
- Two elements that are closely associated with using SOARs are a SOAR playbook and a runbook
- Following a cybersecurity incident, it must be fully investigated
- IP software monitors can provide insight into an incident

Summary (2 of 2)

- Forensics is the application of science to questions that are of interest to the legal profession
 - Digital forensics uses technology to search for evidence pertaining to a cybercrime or damage that occurred during a cyber incident
- As soon as the incident response team begins its work, it must start and maintain a strict chain of custody
- There are different software and hardware forensics tools available for analysis